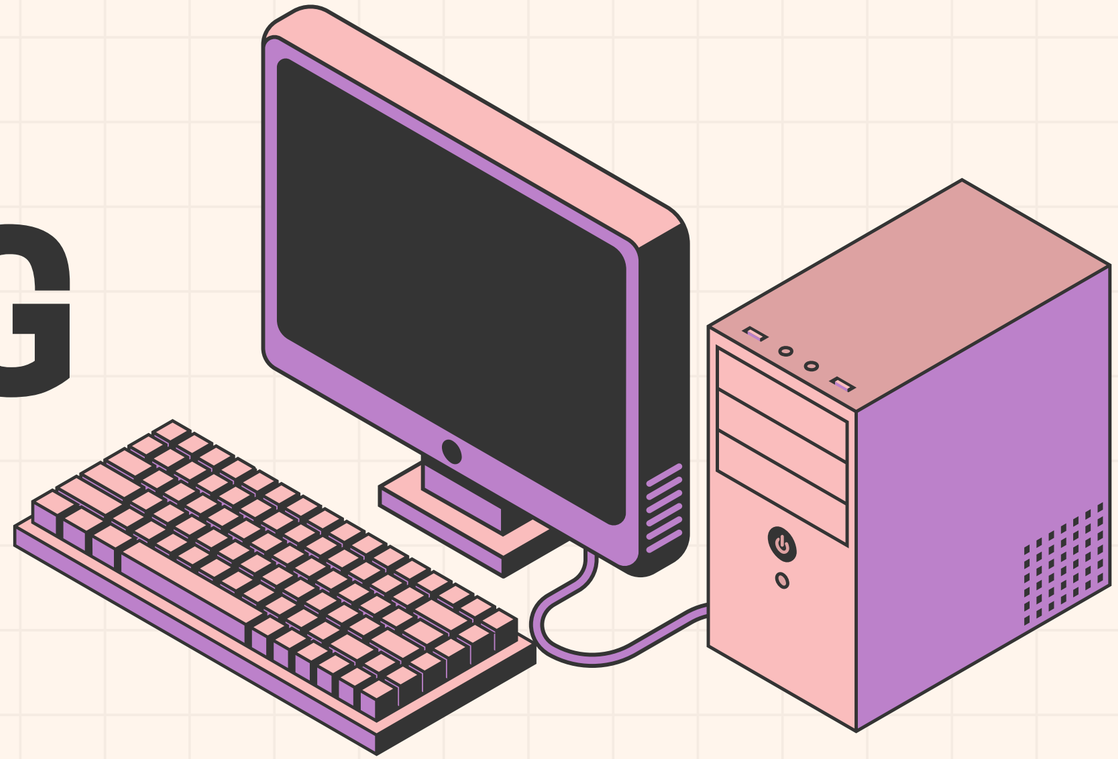
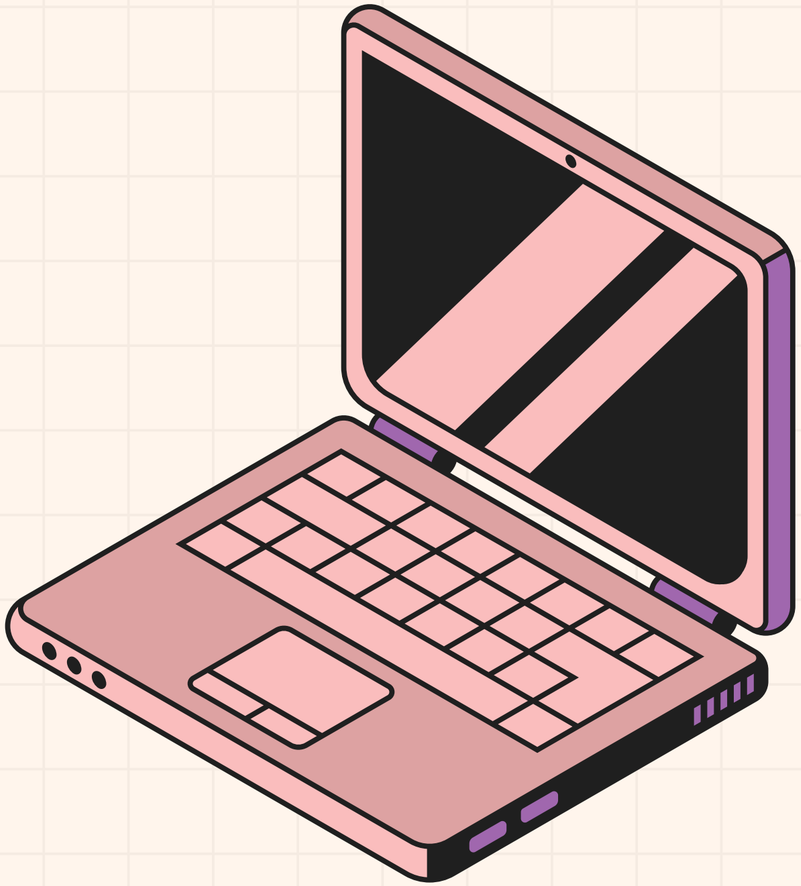
PRUEBA DE PENTESTING

Criptografía y Seguridad



PREPARACIÓN

para este ejemplo, tomaremos el sitio unam.mx, además crearemos un script en bash para ejecutar los programas necesarios en nuestra recolección de información



EL SCRIPT

para realizar el pentesting, se desarrollo el siguiente script de bash, en el cual, simplemente se reciben como parámetros el nombre del archivo a guardar, la pagina o ip que queremos revisar y se regresa un archivo con el nombre seleccionado que contiene toda la información recolectada

```bash
#!/bin/bash

# Función para mostrar ayuda
usage() {
  echo "Uso: $0 [-g nombre_archivo] <dominio/IP>"
  echo "  -g <nombre>   Especifica el nombre del archivo de salida (por defecto log.txt)"
  exit 1
}

# Valores por defecto
OUTPUT_FILE="log.txt"

# Parsear argumentos
while getopts "g:" opt; do
  case $opt in
  g) OUTPUT_FILE="$OPTARG" ;;
  *) usage ;;
  esac
done
shift $((OPTIND - 1))

# Verificar que se proporcionó un dominio o IP
if [ -z "$1" ]; then
  usage
fi
TARGET="$1"

# Iniciar archivo de log
echo "Pentesting Report for $TARGET" >"$OUTPUT_FILE"
echo "Fecha de escaneo: $(date)" >>"$OUTPUT_FILE"
echo "============================" >>"$OUTPUT_FILE"

# WHOIS para obtener información de dominio
echo "Obteniendo información WHOIS: " >>"$OUTPUT_FILE"
whois "$TARGET" >>"$OUTPUT_FILE"
echo "============================" >>"$OUTPUT_FILE"

# Comprobar conectividad y latencia
echo "Comprobando conectividad (Ping): " >>"$OUTPUT_FILE"
ping -c 4 "$TARGET" >>"$OUTPUT_FILE"
echo "============================" >>"$OUTPUT_FILE"
```

RECOPILACIÓN DE INFORMACION

whois

en Este paso inicial del pentesting, evaluaremos los resultados que nos dio nuestro script, asi pues, la primera herramienta que usamos es whois, puesta esta nos da información de caracter administrativo que nos puede ser de utilidad.

```
Domain Name:        unam.mx

Created On:         1989-03-31
Expiration Date:    2025-03-30
Last Updated On:    2024-01-27
Registrar:          AKKY ONLINE SOLUTIONS, S.A. DE C.V.
URL:                http://www.akky.mx
Whois TCP URI:      whois.akky.mx
Whois Web URL:      http://www.akky.mx/herramientas/whois.jsf

Registrant:
   Name:            UNAM
   City:            Mexico
   State:           Distrito Federal
   Country:         Mexico

Administrative Contact:
   Name:            HECTOR BENITEZ PEREZ
   City:            Mexico
   State:           Ciudad de Mexico
   Country:         Mexico

Technical Contact:
   Name:            ALEJANDRO CRUZ SANTOS
   City:            Mexico
   State:           Ciudad de Mexico
   Country:         Mexico

Billing Contact:
   Name:            UNIDAD ADMINISTRATIVA DGTIC
   City:            Mexico
   State:           Ciudad de Mexico
   Country:         Mexico
```

RECOPILACIÓN DE INFORMACION

ping

Ahora, queremos saber si el servidor accesible, por lo que; usaremos la herramienta ping para verificar que el servidor sea accesible.

Podemos ver que, aunque el ping no fue devuelto, el programa nos dice que fue rechazado, lo que significa que el sitio web esta activo, pero tiene protecciones que evitan ciertas peticiones

```
PING unam.mx (2001:1218:3000:180::17) 56 data bytes
From 2806-1060-0200-0001-0000-0000-0000-0001.ipv6.infinitum.net.mx (2806:1060:200:1::1) icmp_seq=1 Destination unreachable: Reject route
to destination
From 2806-1060-0200-0001-0000-0000-0000-0001.ipv6.infinitum.net.mx (2806:1060:200:1::1) icmp_seq=3 Destination unreachable: Reject route
to destination
From 2806-1060-0200-0001-0000-0000-0000-0001.ipv6.infinitum.net.mx (2806:1060:200:1::1) icmp_seq=4 Destination unreachable: Reject route
to destination
```

RECOPILACIÓN DE INFORMACION

host

Como el servidor si esta activo, podemos ver cuales son las ip publicas y como esta segmentadas, con el programa host

también buscamos con dig para confirmar que no se oculten algunas ips publicas

```
============================
IP Pública y segmentos:-
unam.mx has address 132.248.166.20
unam.mx has address 132.248.166.18
unam.mx has address 132.248.166.17
unam.mx has address 132.248.166.19
unam.mx has IPv6 address 2001:1218:3000:180::19
unam.mx has IPv6 address 2001:1218:3000:180::20
unam.mx has IPv6 address 2001:1218:3000:180::18
unam.mx has IPv6 address 2001:1218:3000:180::17
unam.mx mail is handled by 0 unam-mx.mail.protection.outlook.com.
============================
Registros IPv4 e IPv6:-
132.248.166.19
132.248.166.20
132.248.166.18
132.248.166.17
2001:1218:3000:180::17
2001:1218:3000:180::19
2001:1218:3000:180::20
2001:1218:3000:180::18
============================
```

RECOPILACIÓN DE INFORMACION

host

Como el servidor si esta activo, podemos ver cuales son las ip publicas y como esta segmentadas, con el programa host

también buscamos con dig para confirmar que no se oculten algunas ips publicas

```
============================
IP Pública y segmentos:-
unam.mx has address 132.248.166.20
unam.mx has address 132.248.166.18
unam.mx has address 132.248.166.17
unam.mx has address 132.248.166.19
unam.mx has IPv6 address 2001:1218:3000:180::19
unam.mx has IPv6 address 2001:1218:3000:180::20
unam.mx has IPv6 address 2001:1218:3000:180::18
unam.mx has IPv6 address 2001:1218:3000:180::17
unam.mx mail is handled by 0 unam-mx.mail.protection.outlook.com.
============================
Registros IPv4 e IPv6:-
132.248.166.19
132.248.166.20
132.248.166.18
132.248.166.17
2001:1218:3000:180::17
2001:1218:3000:180::19
2001:1218:3000:180::20
2001:1218:3000:180::18
============================
```

RECOPILACIÓN DE INFORMACION

traceroute

Ahora, como ya tenemos las direcciones ip publicas usaremos traceroute para saber que saltos ha dado el sistema

En este caso, vemos que llega al limite de 30 saltos y casi todos son saltos invalidos, lo que significa que el sitio esta portegido en contra de estos escaneos y camufla la conexion.

```
Ruta y saltos al dominio:
traceroute to unam.mx (2001:1218:3000:180::18), 30 hops max, 80 byte packets
 1  2806-104e-001e-35b7-e626-86ff-fe9b-3da0.ipv6.infinitum.net.mx (2806:104e:1e:35b7:e626:86ff:fe9b:3da0)  1.352 ms  4.718 ms  5.021 ms
 2  * * *
 3  2806-1060-0200-0001-0000-0000-0000-0002.ipv6.infinitum.net.mx (2806:1060:200:1::2)  9.532 ms * *
 4  * * *
 5  * * *
 6  * * *
 7  * * *
 8  * * *
 9  * * *
10  * * *
11  * * *
12  * * *
13  * * *
14  * * *
15  * * *
16  * * *
17  * * *
18  * * *
19  * * *
20  * * *
21  * * *
22  * * *
23  * * *
24  2806-1060-0200-0001-0000-0000-0000-0001.ipv6.infinitum.net.mx (2806:1060:200:1::1)  6.994 ms !<6> * *
```

RECOPILACIÓN DE INFORMACION

nmap

por ultimo, como ya vimos que el servidor esta activo y que nos es posible obtener informacion de el, por lo tanto, usaremos nmap para escanear los puertos y saber que estan ejecutando.

como podemos ver, el servidor que aloja el sitio web tiene 2 puertos abiertos, en el 80 esta corriendo un servidor apache version 1.27.2, en el puerto 443 se esta corriendo nginx para 2.4.51

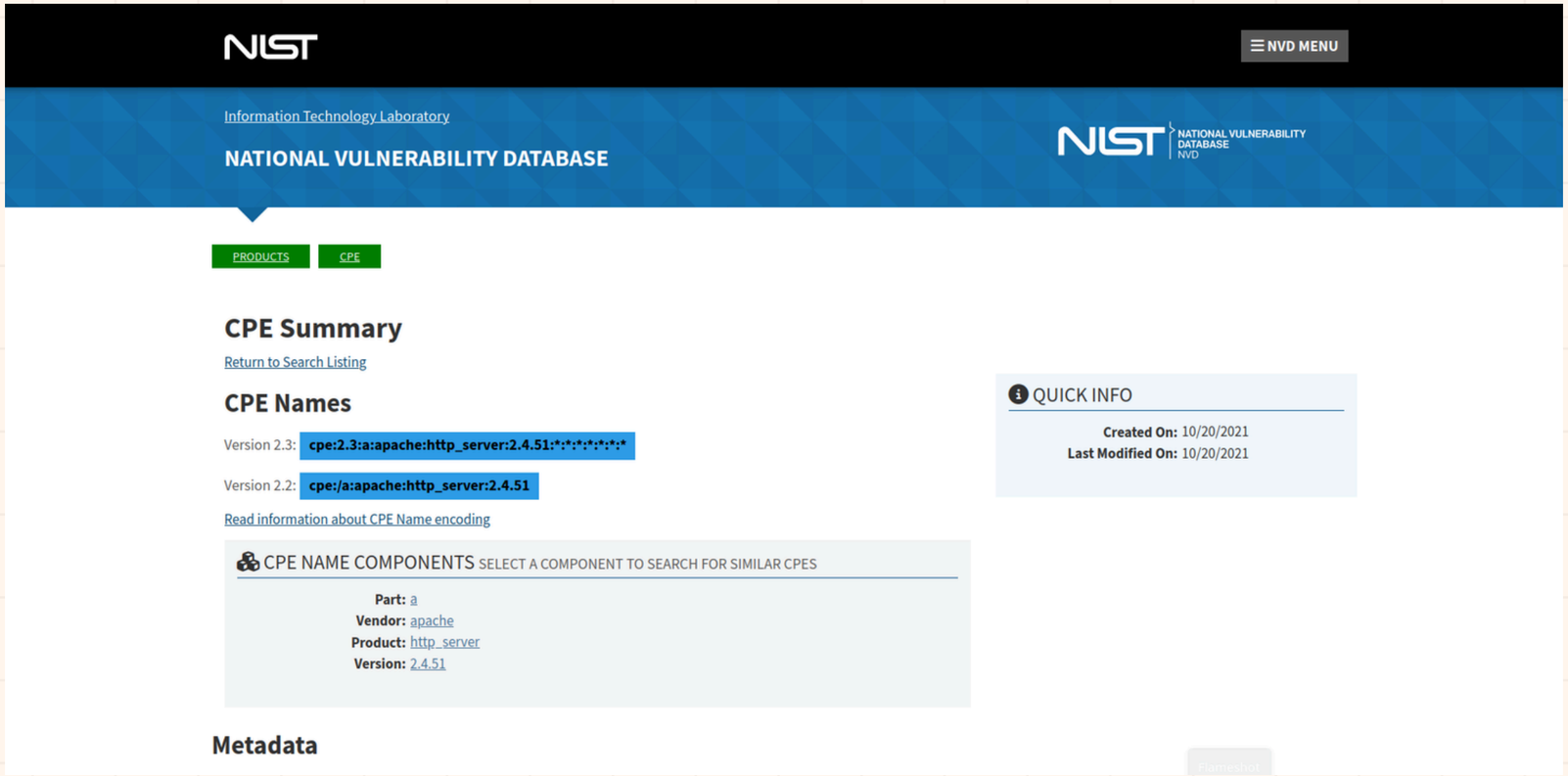
```
Escaneo de puertos con nmap:-
Starting Nmap 7.98 ( https://nmap.org ) at 2024-02-24 23:41 -0600
Nmap scan report for unam.mx (132.248.166.19)
Host is up (0.046s latency).
Other addresses for unam.mx (not scanned): 2001:1218:3000:180::18 2001:1218:3000:180::20 2001:1218:3000:180::19 2001:1218:3000:180::17
132.248.166.17 132.248.166.20 132.248.166.18
Not shown: 979 filtered tcp ports (no-response), 19 filtered tcp ports (host-unreach)
PORT    STATE SERVICE  VERSION
80/tcp  open  http     Apache httpd 2.4.51 ((Unix))
443/tcp open  ssl/http nginx 1.27.2

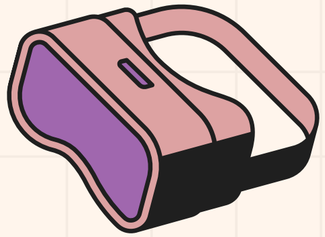
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.02 seconds
============================
============================
```

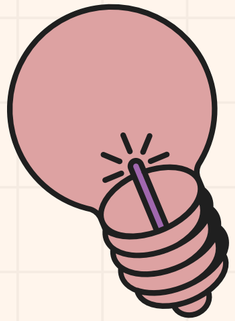
ANÁLISIS DE LA INFORMACION

notamos que con la información administrativa podemos hacer ataques de pishing, se pueden usarse correos electrónicos. llamadas telefonicas u otros metodos

además, como sabemos que versiones de apache y nignx esta usando, podemos buscar que vulnerabilidades esta buscando, para esto usaremos la pagina del NIST que nos guarda un listado de todas las vulnerabilidades regstradas







GRACIAS

